

Informe de Auditoría

Recepción Electrónica (RE)

Documento de apoyo para revisión de cumplimiento y alineación del sistema Recepción Electrónica con las políticas internas PSI aplicables.

Campo	Descripción
Tipo de documento	Informe de Auditoría
Código	IA-RE-001
Producto	Recepción Electrónica (RE)
Versión	1.0
Fecha	2026-06-26
Responsable	Área de Sistemas / Desarrollo
Clasificación	Uso interno
Estado	Vigente

1. Objetivo

Presentar un resumen ejecutivo de los controles, evidencias y documentos que soportan la alineación de Recepción Electrónica con los lineamientos de seguridad definidos en **PSI.01**, **PSI.05** y **PSI.12**.

2. Alcance

El alcance considera el sistema base de Recepción Electrónica:

- Autenticación y recuperación de contraseña.
- Usuarios, roles y permisos.
- Empleados.
- Visitantes.
- Registros de visitas.
- Validación de QR.
- Kiosco y eventos.
- Reportes y exportaciones.
- Configuración general.
- Anonimización posterior a eliminación permanente.

Las integraciones opcionales se documentan en los documentos específicos de integración.

3. Políticas y lineamientos revisados

Política	Nombre	Relación con RE
PSI.01	Política de requisitos de seguridad en los proyectos	Define requisitos de seguridad, documentación, gestión del proyecto y controles aplicables al sistema.
PSI.05	Política de control de accesos	Define control de accesos, permisos, contraseñas, restricción de información y protección de datos.
PSI.12	Política de desarrollo seguro	Define desarrollo seguro, pruebas, separación de ambientes, obligaciones y buenas prácticas de seguridad.

4. Resumen de cumplimiento contra PSI

4.1 PSI.12 - Política de Desarrollo Seguro

Principios de desarrollo seguro

Lineamientos considerados:

- Simplicidad.
- Contraseñas seguras.
- Aprender de los errores.
- Bases de seguridad.
- Enfoque de riesgos.

Cumplimiento en RE:

- El sistema utiliza autenticación con usuario y contraseña.
- Las contraseñas se almacenan mediante hash.
- El acceso se controla por roles y permisos.
- El backend valida la información recibida antes de procesarla.
- Los errores se manejan mediante mensajes controlados.
- La información sensible no se expone en respuestas, reportes o documentación.
- Los riesgos principales se documentan en la matriz de riesgos.

Evidencia relacionada:

- MT-RE-001-ManualTecnico
- DF-RE-001-Funcional
- MR-RE-001-MatrizRiesgos
- TR-RE-001-MatrizTrazabilidadISO

Pruebas

Lineamientos considerados:

- Pruebas funcionales.
- Pruebas de permisos.
- Pruebas de aceptación.
- Pruebas de reportes.
- Pruebas de errores controlados.
- Pruebas de seguridad cuando aplique.

Cumplimiento en RE:

- Existe un plan de pruebas para validar los flujos principales.
- Se consideran pruebas de login, recuperación de contraseña, visitantes, QR, entradas, salidas, reportes, permisos y errores.
- Las pruebas se ejecutan con datos demo.

Evidencia relacionada:

- PT-RE-001-Pruebas
- Capturas de login, visitantes, QR, eventos, reportes, roles y configuración.

Separación de ambientes de desarrollo, pruebas y producción

Lineamientos considerados:

- Separación de ambientes.
- Ambiente de pruebas funcionales.
- Ambiente de pruebas similar a producción.
- Producción separada de desarrollo y pruebas.
- Prohibición de uso de datos reales de producción en pruebas.

Cumplimiento en RE:

- El sistema se configura mediante variables de entorno.
- Las bases de datos, URLs, correos, integraciones y credenciales pueden separarse por ambiente.
- La documentación no incluye valores reales de variables sensibles.
- Las pruebas se documentan con datos ficticios, demo o anonimizados.

Evidencia relacionada:

- MI-RE-001-Instalacion
- MT-RE-001-ManualTecnico
- PT-RE-001-Pruebas

Lineamientos

Lineamientos considerados:

- Identificar requisitos de seguridad.
- Documentar el sistema.
- Controlar cambios.
- Realizar pruebas.
- Controlar migraciones entre ambientes.
- Proteger información sensible.

Cumplimiento en RE:

- Los requerimientos se documentan en el documento de requerimientos.
- El comportamiento funcional se documenta en el documento funcional.
- La arquitectura, API, base de datos e instalación se documentan por separado.
- La matriz de trazabilidad relaciona los controles PSI con los documentos y evidencias.

Evidencia relacionada:

- DR-RE-001-Requerimientos
- DF-RE-001-Funcional
- MT-RE-001-ManualTecnico
- API-RE-001-API
- DB-RE-001-DiccionarioBD
- TR-RE-001-MatrizTrazabilidadISO

Obligaciones de la Dirección de Sistemas

Lineamientos considerados:

- Asignar responsabilidades.
- Supervisar controles de seguridad.
- Asegurar pruebas antes de liberar.
- Controlar cambios y migraciones.
- Mantener evidencia documental.

Cumplimiento en RE:

- La documentación identifica responsables y estado documental.
- El sistema cuenta con plan de pruebas.
- La instalación y despliegue están documentados.
- La matriz de riesgos identifica amenazas y controles.
- La trazabilidad PSI vincula política, control, documento y evidencia.

Evidencia relacionada:

- MA-RE-001-Administracion
- MI-RE-001-Instalacion
- MR-RE-001-MatrizRiesgos
- PT-RE-001-Pruebas
- TR-RE-001-MatrizTrazabilidadISO

Obligaciones de desarrolladores internos

Lineamientos considerados:

- Aplicar desarrollo seguro.
- Validar entradas.
- Proteger datos sensibles.
- Evitar exposición de secretos.
- Mantener documentación actualizada.
- Realizar pruebas de seguridad cuando aplique.

Cumplimiento en RE:

- El sistema valida datos en frontend y backend.
- Los accesos se restringen por roles y permisos.
- Las contraseñas se almacenan mediante hash.
- Los secretos se gestionan mediante variables de entorno.
- Los valores reales de credenciales no se incluyen en la documentación.
- Se documentan riesgos, pruebas, API, base de datos e instalación.

Evidencia relacionada:

- MT-RE-001-ManualTecnico
- API-RE-001-API
- DB-RE-001-DiccionarioBD
- MR-RE-001-MatrizRiesgos

Gerencia de desarrollo de software

Lineamientos considerados:

- Validar el ciclo de desarrollo.
- Separar ambientes.
- Aprobar cambios.
- Mantener evidencia de pruebas.
- Registrar riesgos y controles compensatorios.

Cumplimiento en RE:

- La documentación del sistema se encuentra versionada.
- El plan de pruebas permite registrar resultado y evidencia.
- La matriz de riesgos documenta riesgos principales y controles.
- La matriz de trazabilidad permite demostrar relación entre PSI y RE.

Evidencia relacionada:

- MR-RE-001-MatrizRiesgos
- PT-RE-001-Pruebas
- TR-RE-001-MatrizTrazabilidadISO

Pruebas realizadas

Pruebas consideradas:

- Login.
- Recuperación de contraseña.
- Registro de visitantes.
- Verificación de visitante.
- Envío de QR.
- Validación de QR.
- Entrada y salida.
- Kiosco y eventos.
- Roles y permisos.
- Reportes.
- Anonimización posterior a eliminación permanente.

Evidencia relacionada:

- PT-RE-001-Pruebas
- Capturas anexas de ejecución.

4.2 PSI.05 - Política de Control de Accesos

Control de accesos

Lineamientos considerados:

- Acceso autorizado.
- Privilegios minimos.
- Gestión de usuarios.
- Gestión de accesos de administrador.
- Revisión de derechos de acceso.
- Uso de información de autenticación secreta.

Cumplimiento en RE:

- El acceso al sistema requiere usuario y contraseña.
- Los módulos visibles dependen del rol del usuario.
- Las rutas API se protegen mediante validación de token y rol.
- Los permisos se administran desde configuración y roles.

- Los usuarios inactivos o eliminados permanentemente dejan de operar en el sistema.

Evidencia relacionada:

- MA-RE-001-Administracion
- DF-RE-001-Funcional
- API-RE-001-API
- MU-RE-001-ManualUsuario

Enmascaramiento de datos

Lineamientos considerados:

- Protección de datos personales.
- No exposición de contraseñas.
- No exposición de secretos.
- Uso de datos demo o anonimizados en pruebas.
- Restricción de información visible por rol.

Cumplimiento en RE:

- La documentacion no incluye valores reales de .env.
- Las evidencias no deben mostrar contraseñas, tokens, QR reales ni datos personales completos.
- Las contraseñas no se muestran en claro.
- Los reportes y módulos se consultan conforme a permisos.
- Las pruebas se realizan con datos demo o anonimizados.

Evidencia relacionada:

- PT-RE-001-Pruebas
- TR-RE-001-MatrizTrazabilidadISO
- MA-RE-001-Administracion

Anonimización de datos

Lineamientos considerados:

- Reducir exposición de datos personales.
- Mantener trazabilidad sin identificar directamente a la persona.
- Evitar recuperación operativa de datos personales una vez cumplido el periodo definido.

Cumplimiento en RE:

- La eliminación permanente oculta el registro en RE mediante `eliminado_permanente`.
- El registro se conserva en base de datos para trazabilidad.

- Al cumplirse 30 días desde la eliminación permanente, el proceso automático de anonimización sobrescribe datos personales.
- Se anonimizan datos como nombre, apellidos, correo, teléfono, fotografía, tokens y datos de identificación aplicables.

Evidencia relacionada:

- Backend: proceso automático de anonimización de eliminados.
- Matriz de trazabilidad TR-RE-001-MatrizTrazabilidadISO

4.3 PSI.01 - Requisitos de seguridad en proyectos

Seguridad en la gestión del proyecto

Lineamientos considerados:

- Requisitos de seguridad.
- Documentacion del proyecto.
- Documentación del proyecto.
- Evidencia de pruebas.
- Resguardo de información crítica.

Cumplimiento en RE:

- El proyecto cuenta con documentación funcional, técnica, administrativa, de base de datos, API, pruebas, riesgos y trazabilidad.
- Los roles y permisos del sistema se encuentran documentados.
- Los comandos de instalación y despliegue se describen en el documento de instalación.
- Las variables de entorno se documentan solo por nombre, sin valores reales.

Evidencia relacionada:

- DR-RE-001-Requerimientos
- DF-RE-001-Funcional
- MA-RE-001-Administracion
- MT-RE-001-ManualTecnico
- MI-RE-001-Instalacion
- TR-RE-001-MatrizTrazabilidadISO

5. Resumen tabular de evidencias

Tema PSI	Cómo lo cumple RE	Documento / evidencia
Principios de desarrollo seguro	Autenticación, roles, validaciones, manejo de errores y protección de datos.	MT-RE-001, DF-RE-001, MR-RE-001
Pruebas	Casos funcionales, permisos, reportes, errores y seguridad.	PT-RE-001
Separación de ambientes	Configuración por .env, bases separadas y datos demo.	MI-RE-001, MT-RE-001
Lineamientos	Requerimientos, documentación, control de cambios y trazabilidad.	DR-RE-001, TR-RE-001
Obligaciones	Responsables, pruebas, despliegue y control documental.	MA-RE-001, PT-RE-001
Control de accesos	Roles, permisos, token, rutas protegidas y visibilidad por perfil.	MA-RE-001, API-RE-001
Enmascaramiento de datos	No exponer secretos, contraseñas, tokens, QR reales ni datos personales completos.	PT-RE-001, TR-RE-001
Anonimización	Eliminación permanente oculta en RE y anonimiza datos después de 30 días.	PT-014, backend de RE

6. Conclusión

Recepción Electrónica cuenta con documentación, controles y evidencia que permiten demostrar su alineación con los lineamientos revisados de **PSI.01**, **PSI.05** y **PSI.12**.

El sistema contempla control de accesos por rol, protección de contraseñas, gestión de variables de entorno, separación de ambientes, pruebas funcionales, trazabilidad documental y anonimización posterior a eliminación permanente.